

Manual 14 - PCI DSS v4.0.1 Controlled Implementation

Authority boundary: practical implementation guidance based on the current PCI SSC source state. This is not PCI SSC endorsement, certification, an official translation, legal advice, or a substitute for required qualified validation.

Manual 14 — PCI DSS Implementation Paths

Essential path

For smaller or lower-complexity environments that still require disciplined PCI DSS scoping and evidence. Minimum outputs: CDE scope statement, data-flow diagram, asset inventory, responsibility matrix, core configuration standards, access/MFA evidence, vulnerability evidence, logging evidence, incident-response evidence, third-party attestations, and remediation register.

Structured path

For organizations with multiple applications, service providers, business units, or formal compliance operations. Adds control ownership, evidence calendars, change-driven reassessment, service-provider dependency mapping, secure-development evidence, penetration-test governance, exception/compensating-control records, and management reporting.

Enhanced path

For complex enterprises, high transaction volumes, hybrid/multi-cloud environments, extensive third-party dependencies, or environments requiring continuous assurance. Adds automated evidence collection where appropriate, continuous control monitoring, risk-based sampling, dependency graphing, control-health metrics, integrated GRC workflows, and formal management assurance.

Evidence object schema

Every control implementation should record:

- requirement/control objective
- applicability and scope
- accountable owner

- responsible operator
- implementation procedure
- operating frequency
- evidence artifact
- evidence repository/location
- retention expectation
- reviewer/test procedure
- result/status
- exception or compensating-control reference
- remediation owner/date
- reassessment trigger

Decision controls

The controlled manual must explicitly separate:

- defined approach vs customized approach where applicable;
- underlying security requirements vs SAQ/ROC/AOC validation instruments;
- PCI DSS requirements vs adjacent PCI standards;
- PCI DSS obligations vs contractual/acquirer/payment-brand requirements;
- PCI DSS requirements vs jurisdiction-specific law;
- technical remediation vs formal exception/compensating-control governance.

Publication rule

Implementation-path maturity must never be represented as certification status. Publication requires exact-candidate QA, durable artifacts, provenance, release-registry reconciliation, and sequential predecessor clearance.

Manual 14 — PCI DSS v4.0.1

Controlled Implementation

Chapter 01 — Governance and PCI DSS operating model

Establish an accountable PCI DSS operating model with executive sponsorship, a named program owner, control owners, operators, reviewers, and escalation paths. Maintain a compliance calendar, decision log, evidence register, remediation register, and change-triggered reassessment process. Evidence should show who performed each activity, when it occurred, what was reviewed, what result was obtained, and where the retained artifact resides.

Chapter 02 — Applicability and entity/validation boundaries

Determine why PCI DSS applies, which legal entities and environments are in scope, and which validation path is expected by the relevant acquiring or payment-brand relationships. Keep PCI DSS obligations distinct from contractual, acquirer, payment-brand, and jurisdiction-specific legal obligations. Record applicability decisions, assumptions, exclusions, and the authority used for each conclusion.

Chapter 03 — Account data and protection boundaries

Classify account data, including primary account number and sensitive authentication data, and define permitted collection, processing, transmission, display, and storage patterns. Maintain explicit retention and disposal rules, masking/truncation requirements, and cryptographic protection decisions. Evidence should tie each data class to systems, flows, owners, retention periods, and approved protection mechanisms.

Chapter 04 — Scoping and cardholder-data-environment boundaries

Define the cardholder data environment and all connected-to or security-impacting systems. Use repeatable scoping procedures that examine network paths, identities, administrative access, shared services, cloud dependencies, security tooling, and third parties. Reassess scope after material architecture, business, vendor, payment-flow, or control changes.

Chapter 05 — Data flows and segmentation

Maintain current payment and account-data flow diagrams that show entry, processing, storage, transmission, tokenization, encryption, third-party handoffs, and exit. Where segmentation is used to reduce scope, document the segmentation objective, technical enforcement points, administrative dependencies, test method, and evidence of continued effectiveness.

Chapter 06 — Roles, validation and assurance pathways

Define management, operational, internal-assurance, QSA/ISA, ASV, acquirer, and payment-brand roles without blurring responsibilities. Distinguish SAQ, ROC, and AOC instruments from the underlying security requirements. Internal readiness work may prepare evidence but must not be represented as replacing qualified external validation when external validation is required.

Chapter 07 — Defined, customized and compensating approaches

For each applicable requirement, identify whether the defined approach or a permitted customized approach is used. Where compensating controls are relevant, maintain the documented constraint, objective, risk analysis, control design, validation method, approval, expiration/reassessment point, and evidence. Never use an exception record to silently waive an applicable requirement.

Chapter 08 — Evidence architecture and implementation paths

Use Essential, Structured, and Enhanced implementation paths to scale operating rigor without changing the underlying obligation. Every evidence object should identify objective, applicability, owner, procedure, frequency, artifact, location, retention, reviewer/test method, result, exception/remediation link, and reassessment trigger.

Chapter 09 — Network security controls

Define network security controls around the CDE and connected environments using approved architecture, configuration standards, change control, rule review, and evidence retention. Maintain inventories of relevant enforcement points and confirm that traffic rules implement documented business and security purposes.

Chapter 10 — Secure configurations

Maintain hardened configuration standards for in-scope system components and track deviations through controlled exceptions. Evidence should include approved baselines, implementation status, change history, review cadence, and verification results. Default credentials, unnecessary services, insecure protocols, and unmanaged configuration drift require explicit treatment.

Chapter 11 — Stored account-data protection

Minimize storage and retain account data only for documented business, legal, or regulatory needs. Apply approved masking, truncation, encryption, key-management, and deletion controls as appropriate. Maintain evidence tying repositories to retention schedules, protection mechanisms, owners, and periodic verification.

Chapter 12 — Transmission cryptography

Protect account data across open or public networks using current approved cryptographic protocols and configurations. Maintain inventories of protected flows, certificates/keys where relevant, endpoint configurations, and periodic validation evidence. Reassess when endpoints, protocols, certificates, cloud services, or payment integrations change.

Chapter 13 — Malware defenses

Identify systems subject to malware risk and implement preventive, detective, monitoring, update, and response controls appropriate to the environment. Where an applicability decision is used, document the rationale and periodic reassessment. Evidence should demonstrate operation, alert handling, update state, and exception management.

Chapter 14 — Secure systems and software

Integrate vulnerability prevention, secure coding, software-change controls, separation of duties, testing, release approval, and security requirements into the development lifecycle. Include payment-page and e-commerce dependencies where relevant. Preserve evidence from requirement definition through deployment and post-change verification.

Chapter 15 — Vulnerability management

Operate a defined vulnerability-management lifecycle covering discovery, risk evaluation, prioritization, ownership, remediation, exception handling, retesting, and metrics. Tool output is evidence input, not proof of

compliance by itself. Link findings to affected assets, remediation decisions, deadlines, and validation results.

Chapter 16 — Change control and configuration assurance

Require documented request, impact assessment, authorization, testing, implementation, rollback planning, and post-implementation verification for material changes. Include security and PCI-scope implications in change records. Emergency changes require equivalent retrospective evidence and timely review.

Chapter 17 — Access-control model

Grant access based on documented business need, least privilege, role design, and separation of duties. Maintain joiner, mover, leaver, privileged-access, and periodic-access-review evidence. Exceptions must be explicit, approved, time-bounded where possible, and reassessed.

Chapter 18 — Identity, authentication and MFA

Maintain controlled identity lifecycles, authentication standards, MFA deployment, service-account governance, secrets handling, and privileged authentication controls. Evidence should show enrollment, configuration, review, revocation, and response to authentication anomalies.

Chapter 19 — Physical access

Control physical access to facilities, systems, media, and areas that can affect account-data security. Maintain visitor, badge, media, disposal, and access-review evidence as applicable. Physical controls should align with the actual deployment model, including colocation and third-party facilities.

Chapter 20 — Logging and monitoring

Define required log sources, collection paths, time synchronization, retention, review, alerting, escalation, and evidence locations. Demonstrate that monitoring is operational and that significant events are investigated and resolved. Changes to systems and data flows should trigger logging-coverage reassessment.

Chapter 21 — Security testing

Maintain a testing program covering relevant vulnerability scanning, penetration testing, segmentation testing, wireless assessment where applicable, and other required security validation. Define scope, independence expectations, frequency, evidence, remediation, and retesting.

Chapter 22 — External scans and ASV boundaries

Where approved scanning-vendor activities are required, distinguish internal readiness scans from official ASV outputs. Open-source or commercial tools may support remediation and engineering but must not be represented as equivalent to qualified validation. Retain scan scope, results, dispute/remediation records, and passing evidence where applicable.

Chapter 23 — Penetration testing and segmentation validation

Define penetration-test objectives, scope, tester independence/competence, methodology, result handling, remediation, and retest expectations. Where segmentation supports scope reduction, test that segmentation remains effective against realistic paths and administrative dependencies.

Chapter 24 — Service-provider and third-party evidence

Inventory service providers that store, process, transmit, secure, or can impact account data. Maintain responsibility matrices, contractual/security commitments, current attestations or equivalent evidence, service descriptions, dependency mapping, and monitoring. Reassess when services, responsibilities, or integrations change.

Chapter 25 — Incident response

Maintain and test an incident-response plan that addresses payment/account-data events, roles, communications, evidence preservation, containment, recovery, notification dependencies, and lessons learned. Link material incidents to scoping, control, and risk reassessment.

Chapter 26 — Exceptions and compensating controls

Use a governed exception process with explicit rationale, affected objective, risk evaluation, approver, expiration, evidence, monitoring, and remediation

path. Compensating-control documentation must show how the original intent and rigor are addressed rather than merely recording a waiver.

Chapter 27 — Validation-path operations

Run readiness activities for the applicable validation path using an evidence inventory, ownership matrix, issue tracker, and quality checks. Keep SAQ, ROC, and AOC preparation distinct from the underlying operation of controls and from assessor judgment.

Chapter 28 — Continuous compliance and control monitoring

Schedule recurring control activities and evidence collection throughout the year rather than treating validation as an annual event. Track control health, missed evidence, stale artifacts, exceptions, change triggers, and remediation aging. Escalate repeated failures to management.

Chapter 29 — Remediation and retesting

For each finding, maintain a clear owner, root cause where practical, action plan, due date, interim risk treatment, evidence of completion, and retest result. Closure requires objective verification, not only a management assertion that work was completed.

Chapter 30 — Management assurance and reporting

Provide management with concise reporting on scope, control health, unresolved findings, exceptions, third-party dependencies, upcoming validation activities, and material changes. Document risk acceptance and escalation decisions and preserve the evidence supporting them.

Chapter 31 — Maturity and capability progression

Improve the operating model from reactive evidence gathering to repeatable, measured, and increasingly automated assurance. Maturity improvements should strengthen evidence quality, timeliness, ownership, monitoring, and change response without being represented as a substitute for meeting applicable requirements.

Chapter 32 — Scenario-based implementation and failure modes

Use realistic scenarios to test scoping, incident handling, failed scans, access anomalies, vendor changes, cloud migrations, e-commerce changes, segmentation failures, and evidence gaps. Scenario exercises are training and control-validation aids, not compliance proof. Record lessons learned and feed them into control and process improvements.